SEEING AND HEARING IS NO LONGER BELIEVING

THE FAKE CUSTOMER PROBLEM



Deepfakes, AI Impersonation and Digital Fraud Against **Small Businesses**

FAKE IDENTITIES · VOICE CLONES · PAYMENT FRAUD · VERIFICATION

ZIRLANDIA MILKOVIC

SEEING AND HEARING IS NO LONGER BELIEVING

THE FAKE CUSTOMER PROBLEM

Deepfakes, AI Impersonation and Digital Fraud Against Small Businesses

ZIRLANDIA MILKOVIC

The Fake Customer Problem
Deepfakes, AI Impersonation and Digital Fraud Against Small Businesses

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 30 October 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Customer Who Does Not Exist 4
Who This Book Is For 6
How to Use This Book 6
The One-Page Fake Check 7

CHAPTERS

1. The New Shape of Fraud 9
2. Fake Identities 13
3. Voice Impersonation 18
4. Deepfake Video and Forged Documents 22
5. Fraudulent Payment Instructions 25
6. The Verification Principle 28
7. Verifying Customers 32
8. Verifying Suppliers, Bosses and Payment Changes 36
9. People and Culture 40
10. Tools That Help (and Their Limits) 44
11. When It Happens, and What the Law Says 48
12. Your 30-Day Plan and Five Case Files 52

APPENDICES

Appendix A: Payment-Change Verification Form 57
Appendix B: Call-Back Card 58
Appendix C: Customer Step-Up Checklist 59
Appendix D: Staff Scripts 60
Appendix E: Incident Log 61
Appendix F: Quarterly Review Sheet 62

BACK MATTER

Glossary 63
A Note on GDPRGard.eu 64
About the Author 65
Notes and Sources 66

Educational Disclaimer

This book is practical, educational guidance for small and medium-sized businesses. It is not legal, banking, insurance, security or data-protection advice, and it does not create a professional relationship between the author and the reader.

Fraud methods, payment rules, consumer law, data-protection law and the EU AI Act differ by country and are changing quickly. Check the current position with your bank, your insurer, a qualified adviser or the police before relying on anything here for a decision that matters.

Following the steps in this book may reduce your risk. It cannot guarantee that a fraud attempt will not succeed or that a loss will be recovered. Checklists, scripts and forms are starting points to adapt, not finished legal documents.

Every business, person and product used in a worked example is **fictional** and is labelled as such. Where the book describes a real case, a figure or a rule, it is sourced in the notes at the back, with the limits of the source stated.

Introduction: The Customer Who Does Not Exist

On a Tuesday afternoon, a bookkeeper at a small firm receives a call from the owner. The voice is the owner's voice: the same pace, the same dry way of saying "right, quick favour". A supplier has changed banks, the owner explains, and a payment due today must go to the new account. It is urgent. The owner is in a meeting and cannot talk long.

The owner is not in a meeting. The owner has never made the call. The voice was built from a few minutes of audio taken from a podcast and a company video.

A few years ago, this would have needed a gifted impersonator. Today it needs a laptop and a free afternoon. That is the change this book is about. **The things we have always used to decide whether someone is real (a voice we know, a face on a screen, a document with the right logo, an email that sounds right) can now be produced on demand, cheaply and convincingly.**

Small businesses feel this first and hardest. You do not have a fraud team. You make payments quickly because speed is how you serve customers. You trust people because trust is how a small business works. Criminals know it.

The fake can come through any door: a customer who does not exist and orders goods that are never paid for; an applicant whose face and references were generated; a "supplier" with a new bank account; a "director" on a video call; a caller who sounds exactly like the person who normally calls.

The good news is that the defence is not a technology you must buy. It is a **procedure**: a small number of rules that make it impossible for any single voice, face or message to move your money or open your systems on its own. Procedures work even when the fake is perfect, because they do not depend on spotting the fake.

The book follows that idea. You will see how the fakes work, then build the verification habits that defeat them: call-backs on numbers you already hold, a second person for money, a cooling-off period for changes, a step-up for risky customers, and a plan for the day something gets through. It ends with a 30-day plan and five fictional case files to practise on.

> **The rule.** Never let the channel an instruction arrives on be the channel you use to check it.

Who This Book Is For

This book is for you if you run, manage or advise a small or medium-sized organisation in Europe or the UK and any of the following is true:

- You pay suppliers, contractors or staff by bank transfer, and the instructions arrive by email, phone or message.
- You take orders, sign up accounts or onboard clients online or by phone, and you rarely meet them.
- You recruit, or work with freelancers, remotely.
- Someone in your business can be rung, messaged or emailed by a person claiming to be the owner, a senior manager, a customer or a supplier.
- You have had a near miss, or you have read about one and wondered whether it could be you.

It is written for owners, finance and operations leads, HR leads, customer-service leads and the person who has been quietly handed "the fraud thing". It assumes no technical background. Technical terms are explained when they first appear and collected in the glossary.

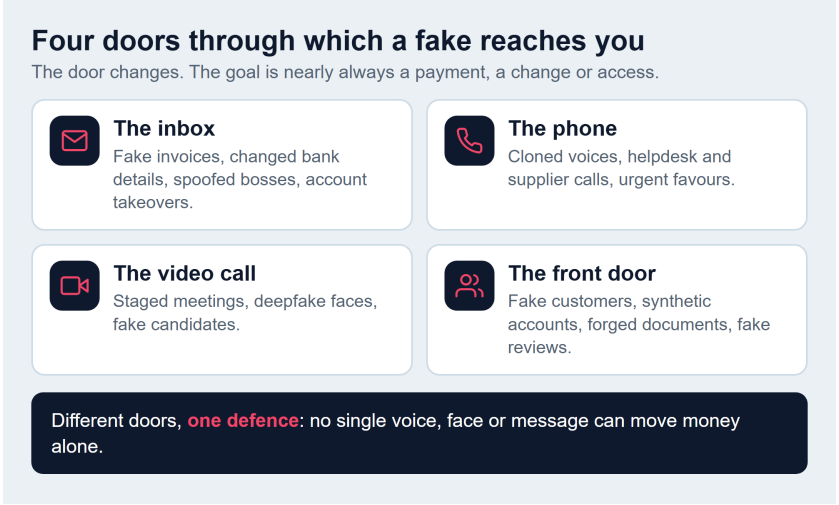
How to Use This Book

You can read the book in an evening, or use it as a manual. Chapters 1 to 5 show **how the fakes work**: identities, voices, video and documents, and payment instructions. Chapters 6 to 10 build the **defences**: the verification principle, procedures for customers and for suppliers and bosses, people, and tools. Chapter 11 covers what to do when it happens and what the law says. Chapter 12 is a 30-day plan and five fictional case files.

Look for these markers:

- **The rule.** A principle worth remembering, set in a dark panel.
- **Fictional.** A worked example using invented people and businesses.
- Check boxes (☐). A step you can tick off. Where a line is blank, write on it.

The appendices contain ready-to-use forms: a payment-change verification form, a call-back card, a customer step-up checklist, a script for staff, an incident log and a quarterly review sheet. Copy them into your own documents or print them.



Four doors through which a fake reaches your business

The One-Page Fake Check

Use these questions on any request that involves money, access, a new relationship or a change to an existing one. If you cannot answer one with a confident yes, pause.

- ☐ Did this request come through a channel **I** chose (a number or address I already hold), not one supplied in the request?
- ☐ Does it ask me to **change** something: bank details, an address, a password, a phone number, a payee?
- ☐ Is there urgency, secrecy or a reason why I cannot check ("I'm in a meeting", "keep this between us")?
- ☐ Would a second person have to approve it, and did they see the original request, not my summary?
- ☐ Has the person been verified by something other than how they look, sound or write?

- ☐ Is there any gap between what was said and what I can see (a different domain, a different account name, a slightly different number)?
- ☐ If I am wrong, how much do I lose, and could I get it back?
- ☐ Have I written down what I checked?

CHAPTER 1

The New Shape of Fraud



Fraud against businesses is old. Forged cheques, fake invoices and persuasive phone calls existed long before the internet. What has changed is the **cost of the lie**. Making a convincing fake used to take skill, time and nerve. Generative AI has removed most of all three.

What AI actually changed

AI did not invent impersonation. It made four things cheap:

- **Believable writing.** Fluent, error-free emails in any language, in any tone, tailored to the recipient from public information. The clumsy spelling that once gave scams away is gone.
- **Cloned voices.** A short sample of someone speaking, from a video, a webinar or a voicemail greeting, can be enough to produce speech that sounds like them.
- **Synthetic faces and video.** Realistic photographs of people who do not exist, and face-swapped video that can run live on a call.
- **Scale.** One person can run hundreds of tailored approaches at once, each looking like a unique, ordinary customer or supplier.

None of this means every call is a fake. It means that **sounding right and looking right are no longer evidence**. They are still useful clues, but a good fake passes them.

The numbers, with caution

The best-known official count comes from the US FBI's Internet Crime Complaint Center. In its 2024 report, business email compromise was the second most costly crime category it tracked, with 21,442 complaints and close to $2.8 billion in reported losses.[1] Three

cautions apply. These are US figures. They include only losses that victims reported. And business email compromise covers many techniques, not only AI-assisted ones. The honest reading is that this fraud type is large and costly, and that voice and video cloning are being added to a trade that was already working.

For a small business, national totals matter less than one question: **what would a single successful fake cost us?** For many firms, one misdirected supplier payment is a month of profit.

The cases that made headlines

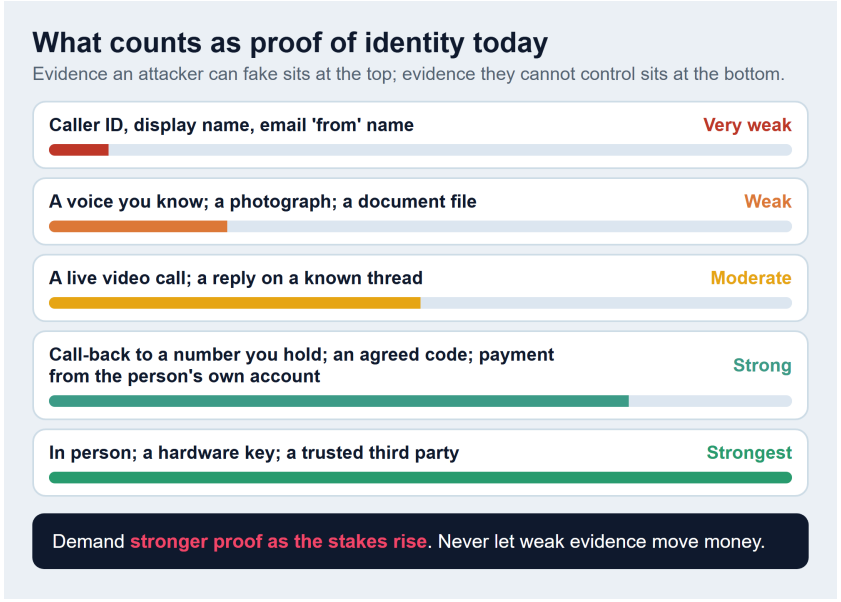
Three real incidents show the pattern. All were reported in the press; the details come from news reporting and company statements, not court findings.

Arup, Hong Kong, January 2024. An employee of the engineering firm joined a video call with what appeared to be the company's chief financial officer and colleagues. The others on the call were reported to be deepfake recreations. Across 15 transactions the employee sent about HK$200 million (roughly US$25 million) to five accounts. Arup later confirmed it had been the victim.[2]

WPP, May 2024. Fraudsters set up a messaging account using a public photo of the chief executive and arranged a video meeting using a cloned voice and footage of senior staff. The target became suspicious and the attempt failed.[3]

Ferrari, July 2024. An executive received messages and then a call from someone imitating the chief executive's voice and accent. The executive asked a question only the real chief executive could answer, and the caller hung up.[4]

Read them together and the lesson is clear. The two failures were stopped by **a person who paused and checked something the fake could not know**. The one success for the criminals depended on a person who felt unable to do so inside a convincing meeting. Your procedures need to make that pause normal, easy and expected.



What counts as proof of identity today

Why small businesses are attractive

- **Fewer layers.** In a large company, a large payment passes through several hands. In a small firm, one person may receive the request, approve it and make the payment.
- **Personal relationships.** You know your suppliers and customers by name. That is a strength, and it is exactly what a fake exploits.
- **Public information.** Small-business owners are often the public face of the firm: websites, videos, interviews, social media. That gives attackers the material they need.
- **Speed as a virtue.** "We pay on time" and "we reply within the hour" are marketing promises. Fraud lives in the gap those promises create.

> **The rule.** Treat every voice, face, document and message as a claim, not proof. Proof comes from a check you control.

Checklist: your starting position

- ☐ I know who in the business can move money, and by what methods.
- ☐ I know which of those people could be reached by a convincing phone call or message.
- ☐ I have listed where my voice, face and role are public.
- ☐ I accept that "it sounded exactly like them" is no longer a reason to skip a check.

CHAPTER 2

Fake Identities



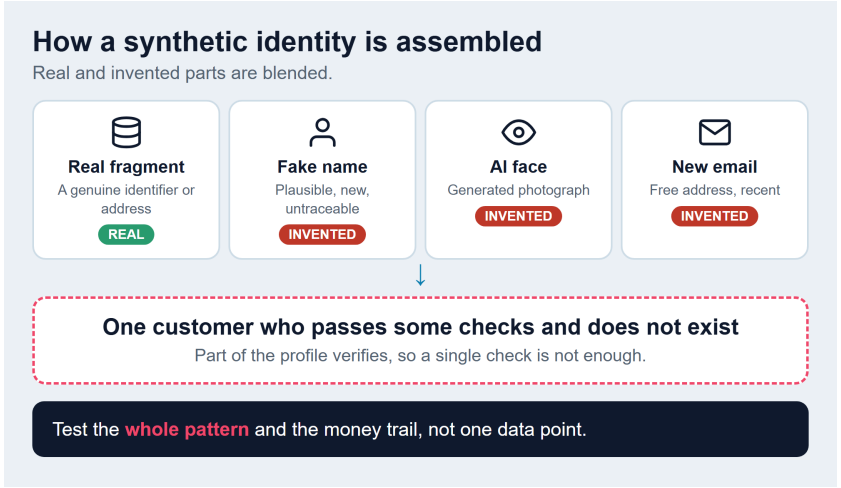
A fake customer is the most direct form of the problem: a person who does not exist, or who is not who they claim, becomes your customer, your employee or your supplier. They exist to take something: goods, services, money, access or data.

Three kinds of fake identity

1. Invented identities. Everything is made up: a name, an email address, a generated photograph, a plausible company, even a website with AI-written pages and fake reviews.

2. Stolen identities. The details belong to a real person who has no idea. Orders and accounts are opened in their name, and they find out when a bill or a debt letter arrives.

3. Synthetic identities. A blend. A real fragment (a genuine identifier or address) is combined with invented details and a generated face. Synthetic identities are hard to catch because part of the profile checks out.



How a synthetic identity is assembled

Where fake identities appear in a small business

Online orders and accounts. Goods ordered on a stolen or invalid payment method; free-trial abuse; reseller scams where a "bulk buyer" asks you to ship before payment clears.

Service sign-ups. Fake accounts used to test stolen cards, abuse promotions, send spam, or open a path for a later attack.

Invoicing and credit accounts. A new "client" requests goods or services on credit terms, using a believable company name and a real-looking registration number. The invoice is never paid and the contact disappears.

Recruitment. Applicants with generated photographs, invented work histories or stolen references; interviews where a face or voice is filtered or replaced. Some are after a salary. Others want access to systems and data once hired.

Freelancers and contractors. A "designer" or "developer" whose portfolio is stolen or generated, who is paid and delivers nothing, or who is a front for someone else.

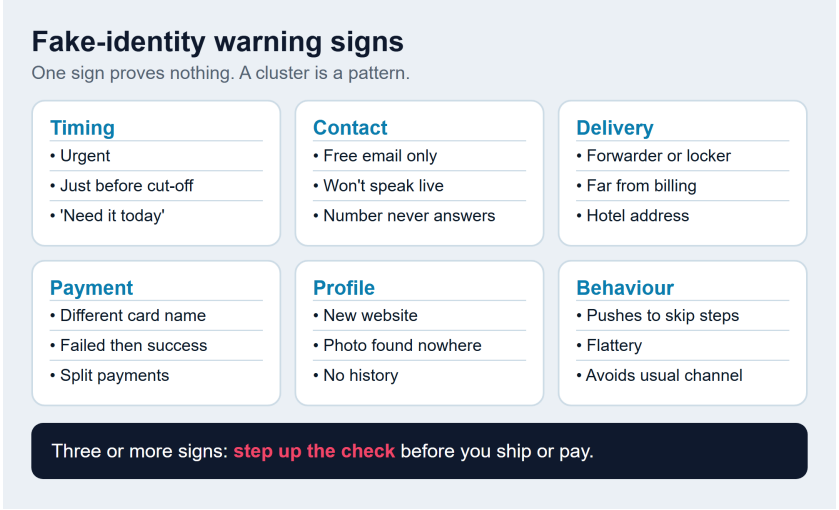
Reviews and referrals. Fake reviews written by AI, praising you or attacking a competitor, and fake testimonials used to build credibility for a bogus supplier.

> **Fictional.** Larkfield Cycles, a four-person online bike-parts shop, received a large order from a "bike-hire company" paying by card. The delivery address was a freight forwarder, the contact email was a free address, and the customer asked for the goods to be sent the same day. The card was later disputed as stolen. The owner lost the goods plus the chargeback fee. None of the signs was proof alone. Together they were a pattern.

Red flags that matter

No single sign proves a fake. Look for **clusters**:

Area	Warning sign
Timing	Unusual urgency; orders just before cut-off; "need it today"
Contact	Only a free email address; a phone number that never answers; reluctance to speak live
Delivery	Freight forwarders, hotels, lockers or an address far from the billing address
Payment	A different name on the card; several failed attempts then a success; split payments
Documents	Perfect but oddly generic; metadata that does not fit; images with odd edges, fonts or shadows
Profile	A photo that does not appear anywhere else; a company with no history; a website only a few weeks old
Behaviour	Pressure to skip the normal process; flattery; an unwillingness to use the usual channel



Fake-identity warning signs, by where they show up

What a fake photograph looks like now

Generated faces used to show telltale errors: mismatched earrings, melted teeth, impossible backgrounds. The best now have few. Do not rely on spotting artefacts. Treat a photograph as a **claim** and test the identity by another route: a live call on a number you looked up, an official registry, a payment from an account in the person's own name, a reference you contact yourself.

What to do

The next chapters build the full defences. For now, adopt three habits:

1. **Match the identity to the money.** The name on the payment should match the name of the customer. If it does not, ask why before you ship.
2. **Look up, do not trust.** Check companies in the official registry for your country, and use contact details you find yourself.
3. **Scale checks to risk.** A £15 order does not need the same checks as a £15,000 order on credit terms (Chapter 7).

Checklist: reduce fake identities

- ☐ I check that the payer name matches the customer name for high-value orders.
- ☐ I verify new business customers in an official registry before giving credit.
- ☐ I do not rely on a photograph or a video as sole proof of identity.
- ☐ For remote hires and contractors, I have a verification step beyond the CV and the interview (Chapter 7).

CHAPTER 3

Voice Impersonation

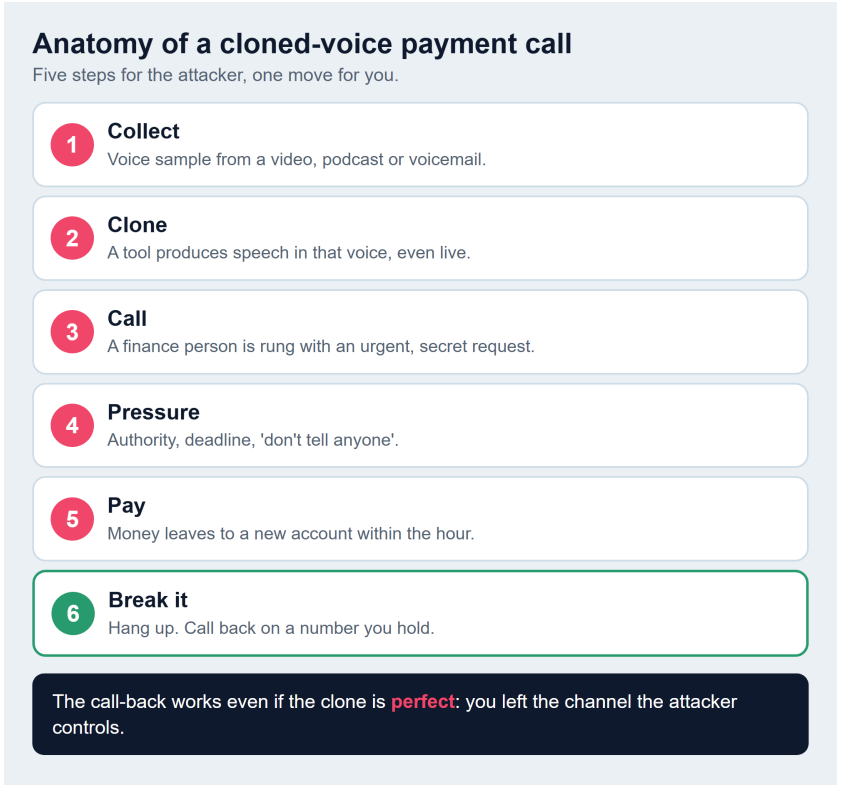


The telephone is where small businesses do their quickest, most trusting work. "Can you just send that over?" is said by phone a hundred times a week. That is why a cloned voice is so effective: it attacks the habit of trusting a voice you know.

How voice cloning attacks work

An attacker needs three things: a **sample** of the target's voice, a **tool** that can produce speech in that voice, and a **story** that makes the request seem normal.

- **Samples** come from public sources: conference talks, podcasts, social videos, a voicemail greeting, even a recorded sales call.
- **Tools** now require little skill. Some work from seconds of audio. Some can run in near real time, so the "caller" can reply to questions.
- **Stories** are borrowed from older frauds: the boss in a hurry, the supplier with new bank details, the customer locked out of their account, the colleague who needs a code.



Anatomy of a cloned-voice payment call

Five calls to expect

1. The urgent boss. "I'm boarding a flight and I need this paid now." The pressure is time, and the secrecy is part of it: "Don't discuss it, it's confidential."

2. The new bank details. A supplier's accounts clerk, or someone who sounds like them, phones to confirm a change of account "so you don't get the old email wrong".

3. The locked-out customer. A caller who sounds like a genuine customer asks to change the phone number, email or address on the account. After that, a password reset is easy.

4. The helpdesk call. "It's the IT provider. We need to reset your multi-factor code." This targets staff, not customers, and the aim is access.

5. The relative emergency. An employee is phoned with a voice that sounds like a family member in trouble and asked to send money. It happens to people at work, and the business may be asked to help.

> **Fictional.** At Pennock & Wray Accountancy, a bookkeeper received a call from "Mr Pennock", who asked her to pay a supplier's invoice to a new account that afternoon. The voice was right. The request was slightly off: Mr Pennock never phoned about payments. She said, "I'll ring you straight back on your mobile." He said there was no need. She rang anyway. The real Mr Pennock was on a train and had made no call. The five-minute habit saved £18,400.

What gives a cloned voice away, and what does not

You may hear odd pauses, flat emotion, repeated phrases, a slightly metallic quality, background sound that does not change, or unusual answers to casual questions. Do not build your defence on this. Good clones lack these flaws, and a poor phone line hides them. Real calls are also full of glitches.

The more reliable tell is **the request itself**: it is urgent, it bypasses normal channels, it asks you to change something, it discourages you from checking. Your defence should depend on the request, not on the quality of the audio.



Photo: The phone is where most small businesses make decisions

Defences that work

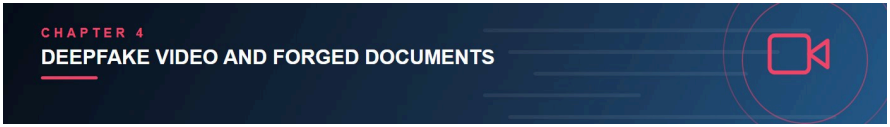
1. **Hang up and call back** on a number you already hold (Chapter 6). Never use a number given during the call.
2. **Ask a question the fake cannot know.** The Ferrari executive did this. Choose something that is not on the internet: a private shared detail, a code word agreed in advance.
3. **Agree code words.** Pick a short phrase for the owner, finance lead and key suppliers, shared in person, changed regularly, never written in email.
4. **Keep your voice off easy sources where you can.** You cannot disappear, but you can keep long, clear recordings of finance staff and owners off public pages.
5. **Make "I'll call you back" a normal sentence.** If staff fear annoying the boss, they will not say it. The boss should say it first, loudly.

Checklist: voice risk

- ☐ Nobody moves money, changes account details or resets access on the strength of a phone call alone.
- ☐ We have agreed code words for the people who can authorise payments.
- ☐ Staff know they are allowed, and expected, to hang up and call back.
- ☐ The owner has told the team, in writing, that "this is urgent" never overrides a check.

CHAPTER 4

Deepfake Video and Forged Documents



Video calls feel safer than phone calls. We see faces, so we feel we know who is there. That feeling is now a weakness.

Video: the three ways it is used

1. The staged meeting. The Arup case is the model: a meeting with several apparently senior people, all fake, and a single real victim who is asked to act. Seeing several "colleagues" agree creates social proof.

2. The one-to-one call. A single deepfake face (a "customer", a "candidate", a "director") appears briefly on a video call. The picture is poor ("my camera is bad") and the call is short.

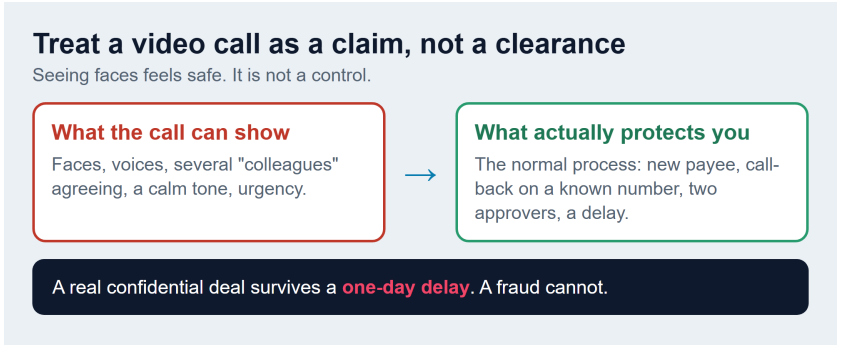
3. The interview. A candidate's face or voice is altered live, or a different person sits the interview than will do the job. For roles with system access, this is a route in.

> **Fictional.** Brightwater Software hired a remote contractor after two friendly video interviews. In the first week, the contractor asked for administrator rights "to speed things up" and used a VPN that placed them in another country. A routine call-back, asking the contractor to show a photo ID to camera and to join a call from the company's own meeting link, was refused. The contract was ended before any data was taken.

Spotting a deepfake: useful, not sufficient

Possible signs include blurry edges around the face or hair, lighting that does not match the room, lip movement that lags speech, odd blinking, a face that stays fixed when the head turns, and a refusal to do a simple movement such as turning side-on or passing a hand in front of the face. Asking for such a movement can help.

But detection is a race, and detection tools produce both false alarms and misses. **The call itself is not the control.** The control is what you do with the request that comes through it.



Treat a video call as a claim, not a clearance

Documents: forged, edited and generated

AI can now produce a convincing passport scan, utility bill, company certificate, bank letter or invoice in minutes. It can also quietly edit a genuine document, changing a number or a name.

Document	How it is abused	A better check
ID scan or photo	Generated or edited image; stolen real document	Use an identity check that reads the document's chip or security features, or a live check, not a photograph sent by email
Proof of address	Edited utility bill or bank statement	Prefer a check that does not rely on a file, such as an electoral or registry lookup or a verified open-banking link
Invoice	Altered bank details, or an entirely fake invoice from a real supplier	Compare against the last genuine invoice and call back (Chapter 8)

Document	How it is abused	A better check
Company certificate	Fake or altered registration	Look up the company in the official register yourself
Reference letter	Written by the candidate or by AI	Contact the referee on a number you find independently
Contract or purchase order	Signed with a pasted signature	Confirm by a second route; use a recognised e-signature service

A PDF is not a safe format. It can be edited, and a pasted signature proves nothing. If a document triggers money, access or a new relationship, **check it against a second source you control**.

Biometrics and liveness: a note of caution

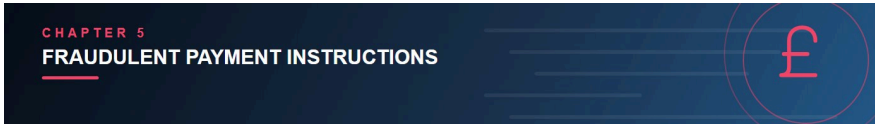
"Liveness" checks ask a person to turn their head, blink or read out numbers, to prove a real person is present. They help against crude fakes, and the better services are tested against presentation attacks. They are not magic. They can be fooled by good deepfakes or by a real person acting under duress. Biometric data is also special-category personal data when used to identify someone, which brings stricter GDPR rules (Chapter 11). For a small business, a simple human step often does more: a short live call on a number you looked up yourself, and a payment from an account in the person's own name.

Checklist: video and documents

- ☐ No payment, account change or access grant is approved on a video call alone.
- ☐ For high-risk roles, we verify identity live, using a method we chose, before granting access.
- ☐ We verify companies and documents against a source we looked up ourselves.
- ☐ We do not treat a PDF, scan or signature image as proof.

CHAPTER 5

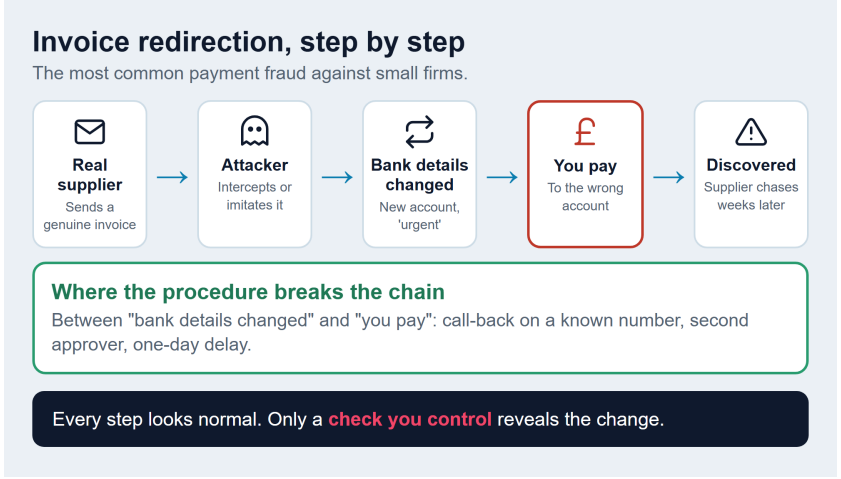
Fraudulent Payment Instructions



Everything in Chapters 2 to 4 leads here. The fake identity, the voice and the face are all instruments. The target is usually a **payment**, or a **change** that will redirect later payments.

The six payment frauds you will meet

1. Invoice redirection. The most common. A supplier's genuine invoice is intercepted or imitated, and the bank details are changed. You pay the criminal, and the supplier never gets paid. Sometimes a real supplier's email account has been taken over, so the message comes from the right address.



Invoice redirection, step by step

2. CEO or director fraud. A request from "the boss" to make an urgent, confidential payment. Chapter 3's calls, plus emails and chat messages.

3. Payroll diversion. An email from "an employee" asks HR to change their bank details before payday. The salary goes to the criminal.

4. Supplier-impersonation onboarding. A new "supplier" presents a believable profile, wins a small order, is paid, and later invites larger prepayments.

5. Overpayment and refund scams. A "customer" pays too much (often with a bad cheque or a stolen card) and asks you to refund the excess to a different account. The original payment later fails, and you have lost the refund.

6. Chargeback and friendly fraud. A real purchase is later claimed to be unauthorised. Not always a fake identity, but evidence matters, and the discipline in this book helps.

The common signature

Almost every payment fraud contains at least one of these:

- **A change.** New account, new payee, new address, new contact.
- **Urgency.** A deadline that leaves no time to check.
- **Secrecy.** "Don't tell anyone", "keep it with me".
- **Authority.** The instruction appears to come from someone senior or someone trusted.
- **A bypass.** A request to skip the normal process "just this once".

Any payment request with a change in it, plus urgency or secrecy, is treated as suspect until independently verified. That one sentence is a procedure you can teach in a minute.

The business case for a small friction

Every check costs a few minutes. Teams push back: "We'll slow suppliers down." Do the arithmetic. A call-back takes about five minutes. A misdirected £18,000 payment takes weeks to unpick and may never be recovered. Frame verification as **protecting suppliers too**: it ensures the money reaches the real supplier.

Fictional. Nightjar Foods paid a monthly £9,200 bill to a packaging supplier. A new "accounts team" email said the account had changed. The bookkeeper replied asking for a letter on headed paper; one arrived within the hour, looking genuine. She paid. Two weeks later the real supplier chased. The letter was fake and the email address differed by one letter. The lesson was not that the bookkeeper was careless. She had done something that felt careful, but she had asked the fake to verify itself.

Checklist: payment instructions

- ☐ Any change of bank details is verified by call-back on a known number before the next payment.
- ☐ No bank detail change is accepted from an email, a letter or an attached form alone.
- ☐ A second person approves every new payee and every payment above our set limit.
- ☐ We pay close attention to payments marked "urgent" or "confidential".

CHAPTER 6

The Verification Principle



If a perfect fake is possible, you cannot defend yourself by getting better at spotting fakes. You defend yourself by arranging your business so that **no single voice, face or message can do harm on its own**. That is what a verification procedure is.

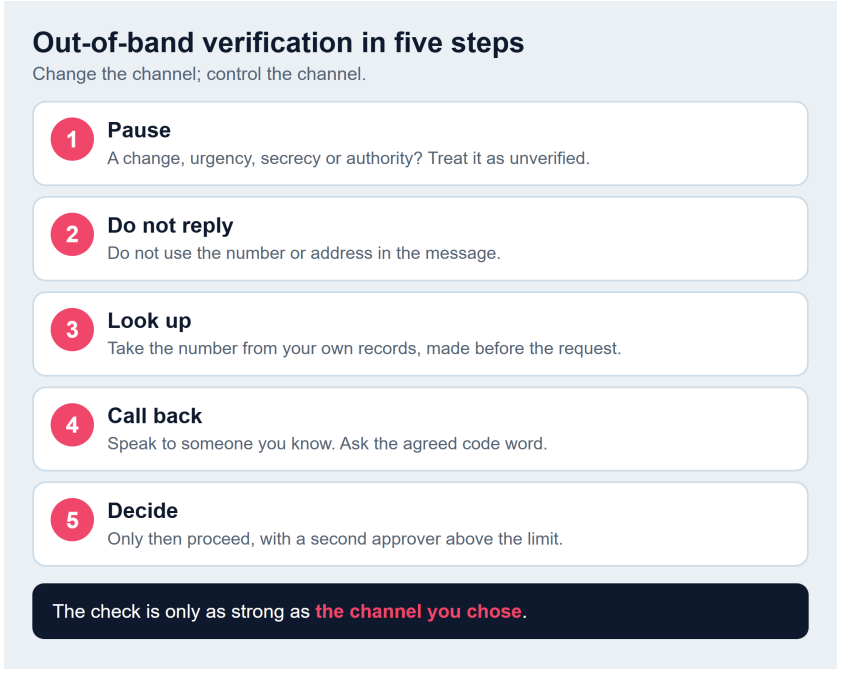
Four moves that defeat almost everything

1. Out-of-band verification. Check the request through a different channel from the one it arrived on, using contact details you already hold. A request by email is verified by phone. A request by phone is verified by calling back. A request on a video call is verified by phone or in person afterwards.

2. Known-good contact details. The number or address you use to check must come from your own records, created **before** the request: your contacts list, an old contract, the supplier's website that you looked up yourself. Never use details given in the message, however convenient.

3. Two-person approval. For money and access above a limit, one person prepares and a second approves. The second person must see the **original request**, not a colleague's summary of it.

4. A cooling-off delay. For changes to payees, bank details or access, impose a delay (a working day is a good start) before the change takes effect. Criminals depend on speed. A delay turns their urgency into a liability.



Out-of-band verification in five steps

The ladder of proof

Not all evidence of identity is equal. Rank it from weak to strong, and demand stronger evidence as the stakes rise:

Strength	Evidence	Use alone?
Very weak	Caller ID, display name, email "from" name	Never
Weak	A voice you know; a photograph; a document file	Never for money or access
Moderate	A live video call; a reply on a known thread	Low-risk actions only
Strong	A call-back to a number you hold; a code agreed in advance; a payment from an account in the person's name	Most business actions
Strongest	Meeting in person; a hardware security key; a trusted third party's confirmation	High-value or high-risk actions

Why the rule works even against a perfect fake

A call-back does not require you to judge the voice. If the fake is calling from a number you do not control, your call goes to the real person, who says, "I didn't call." The fake's skill is irrelevant, because you moved the conversation to a channel it does not control. The same logic applies to every procedure in this book.

> **The rule.** The strength of a check depends on whether the attacker controls the channel. Use a channel they cannot control.

What not to do

- **Do not verify using the requester's own details.** Replying to the email, ringing the number in the signature or sending the "verification form" they attached lets the fake verify itself.
- **Do not ask questions answerable from the internet.** The date of birth, the name of the company founder and the town you work in are all findable.
- **Do not rely on gut feeling.** People are poor at detecting lies, and AI has made it worse.
- **Do not make exceptions for "VIPs".** Fraudsters impersonate exactly those people.



Photo: A known-good channel is a key only you hold

Make it a habit, not a hurdle

Verification works only if people use it. Three practical steps:

1. **Set it in writing.** A one-page rule that everyone has seen, with the owner's signature.
2. **Make it easy.** A printed call-back card on the finance desk, a contacts list with verified numbers, a standard message template for saying "I'll call you back".
3. **Reward the pause.** When someone stops a fake, say thank you in public. When someone triggers a check that turns out unnecessary, say thank you as well.

Checklist: the principle in place

- ☐ We have a written rule that money and access changes are verified out of band.
- ☐ Our contacts list holds verified numbers for suppliers, customers and senior staff.
- ☐ We have a defined approval limit above which a second person must approve.
- ☐ We have a cooling-off delay for payee and bank-detail changes.

CHAPTER 7

Verifying Customers



Not every customer needs to be investigated. A shop that checks the passport of everyone buying a £12 notebook will have no customers. The skill is **proportion**: check little when risk is low, check more as risk rises, and know what makes risk rise.

Step-up verification

Start every customer at a basic level, and **step up** only when a trigger appears. Triggers include a high order value, a request for credit terms, a change of details, a mismatch between name and payment, an unusual delivery address, or a cluster of red flags from Chapter 2.

Step-up verification for customers

Start light. Step up only when a trigger appears.

1. **Basic** · Normal low-value orders
   Standard payment security; confirmation to email given
2. **Match** · Medium value or a minor flag
   Payer name matches; delivery confirmed; confirm to address on file
3. **Verify** · High value, credit, several flags
   Live call to a looked-up number; registry check; payment from own account
4. **Hold** · Strong signs of fraud
   Pause; record the reason; refund to original method only

Proportion keeps customers happy and **keeps fakes out**.

Step-up verification for customers

Level	When	What you do
1. Basic	Normal low-value orders	Standard payment security (card checks, 3-D Secure), order confirmation to the email given
2. Match	Medium value, or a minor flag	Check payer name matches customer; confirm delivery address; send a confirmation to an address on file
3. Verify	High value, new account on credit, or several flags	Live call to a number you looked up; registry check for businesses; ask for payment from a business account
4. Hold	Strong signs of fraud	Pause shipment, refund to the original payment method only, record the reason

Order and fulfilment checks

- **Hold, do not fight.** A short hold on a risky order is easier than a dispute.
- **Refunds go back where the money came from.** Never refund an overpayment to a different account on request. Refund to the original payment method after the funds have fully cleared.
- **Wait for cleared funds** on large orders paid by bank transfer or cheque. A transfer that appears in your account can still be recalled.
- **Send high-value goods to the verified billing address**, or require signature on delivery.
- **Keep the evidence.** Order logs, delivery proof, communication and the checks you did are your defence in a chargeback dispute.

Account recovery: the quiet back door

Many frauds do not target an order. They target an existing customer account: change the email, then reset the password. Protect the recovery process:

- Do not change contact details on the strength of a call or an email alone.
- Send a confirmation to the **old** contact details, and give a delay before a change takes effect.

- Use a step-up for changes of email, phone, address or payout bank account.
- Train your support team in a script (Appendix D) so no one invents a policy under pressure.

> **Fictional.** Mossgate Training sells online courses. A customer wrote to change the email on her account, saying she had lost access. Support, following the script, sent a confirmation to the old address and applied a 24-hour delay. The real customer responded within an hour: she had not asked. The account stayed secure.

Hiring and onboarding remote staff and contractors

Remote hiring needs its own steps:

1. **Verify the person, not the CV.** At least one live video call that you set up yourself, with a request to show government-issued ID to the camera for a role with access to data or money.
2. **Check right-to-work and references the proper way.** Contact referees on numbers you find independently.
3. **Match the payment account** to the name on the contract.
4. **Grant access in stages.** Start with minimum permissions, extend as trust is earned.
5. **Ship equipment to a verified address** and confirm receipt on a live call.

Keep personal-data rules in mind: collect only what you need, tell candidates what you collect and why, and delete it when you no longer need it (Chapter 11).

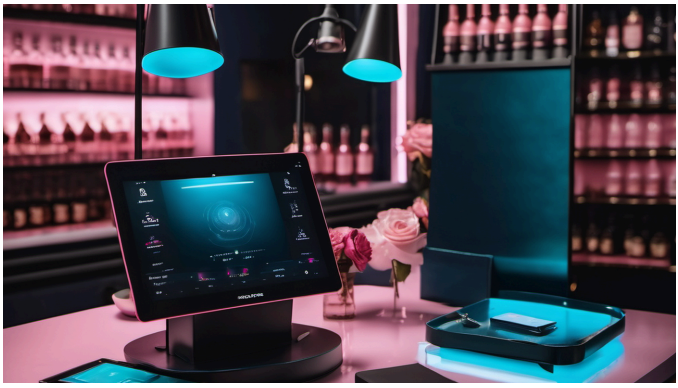


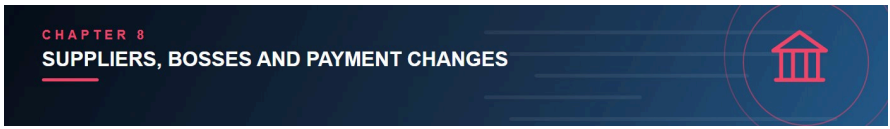
Photo: A busy counter needs checks that take seconds, not minutes

Checklist: customers

- ☐ We have a basic level and a step-up level for customers and know what triggers each.
- ☐ We match payer name to customer name on higher-value orders.
- ☐ We refund to the original payment method only, after funds have cleared.
- ☐ Contact-detail changes are confirmed through the old details, with a delay.
- ☐ Remote hires are verified live, using a method we chose.

CHAPTER 8

Verifying Suppliers, Bosses and Payment Changes

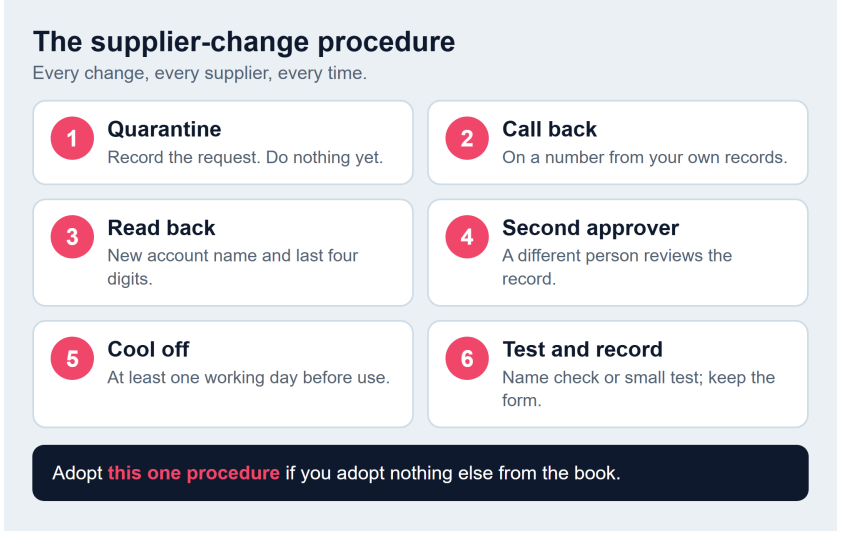


This is the chapter that protects your cash. If you adopt one procedure from this book, adopt this one.

The supplier-change procedure

A change of supplier bank details is a high-risk event. Every one should follow the same steps, whatever the supplier size, whatever the reason:

1. **Receive and quarantine.** Do not act on the request. Record it, with the original message.
2. **Verify out of band.** Call the supplier on a number from your own records, created before the request. Speak to someone you have dealt with before, if possible.
3. **Confirm the details.** Read back the new account name and the last four digits of the account number. Ask why the change is happening.
4. **Second person approves.** A different person checks the verification record and approves the change in the system.
5. **Cooling-off delay.** The new details are not used until a set time has passed (at least one working day).
6. **Test payment and name check.** For a large payment, send a small test first, or use the bank's payee-name check (Chapter 10).
7. **Record.** Keep who, when, how and what was checked (Appendix A).



The supplier-change procedure

A request that arrives with a **new** supplier follows the same steps plus a registry check, a look at their trading history, and, for larger orders, a reference you contact yourself.

Requests from "the boss"

The most dangerous message is the one that looks as if it comes from the person with the authority to override rules. Handle it with a set of agreements made **in advance, in calm**:

- Payments above the limit need two people, **no matter who asks**, including the owner.
- A request that bypasses the process is a signal. The more senior the sender, the more reason to check.
- The owner agrees in writing that staff will not be criticised for verifying.
- Where the owner really must make an urgent payment, they use an agreed method: a code word and a call-back from the finance lead.

> **Fictional.** At Corvin Logistics, the finance lead received a message from the managing director's number: "Need £22k to a new haulier today, discreet please." Corvin's rule said any payment to a new payee needed a call-back and a second approver. The finance lead rang the MD's mobile. The MD's phone had been cloned by SIM-swap, and the message came from the criminal's device. The real MD answered a second phone: no such request. The rule stopped the loss.

Payroll and staff requests

Payroll diversion works because HR feels it would be unkind to question an employee. Make the check kind and normal: "For everyone's protection, we confirm bank changes in person or by phone." Apply it to everyone, including senior staff. Delay the change until after the next payroll if needed, and notify the employee at their old contact details.

Approval limits that fit a small business

You do not need a bank's controls. You need a few numbers set deliberately:

Payment type	Suggested control
Any payment to a new payee	Call-back plus second approver, any amount
Change to existing payee details	Call-back, second approver, cooling-off delay
Payments above your limit (for example 5% of monthly turnover)	Second approver who sees the original request
Urgent or confidential requests	Always step up one level
Payroll bank-detail changes	Verify with the employee through a known channel

Pick limits that match your own cash position. The numbers matter less than the **habit of having numbers**.



Photo: Every invoice is a claim until it is checked

Checklist: suppliers and bosses

- ☐ The supplier-change procedure is written and followed for every change.
- ☐ No one, including the owner, can move money above the limit alone.
- ☐ A second approver sees the original request.
- ☐ Payroll bank-detail changes are verified with the employee through a known channel.
- ☐ We keep a record of every verification.

CHAPTER 9

People and Culture



Procedures fail when people feel unable to use them. The strongest control in a small business is a team that knows what to do, is allowed to do it, and is thanked for doing it.

Why people give in

Fraudsters do not beat people with technology. They beat them with **pressure**. The same pressures appear in almost every case:

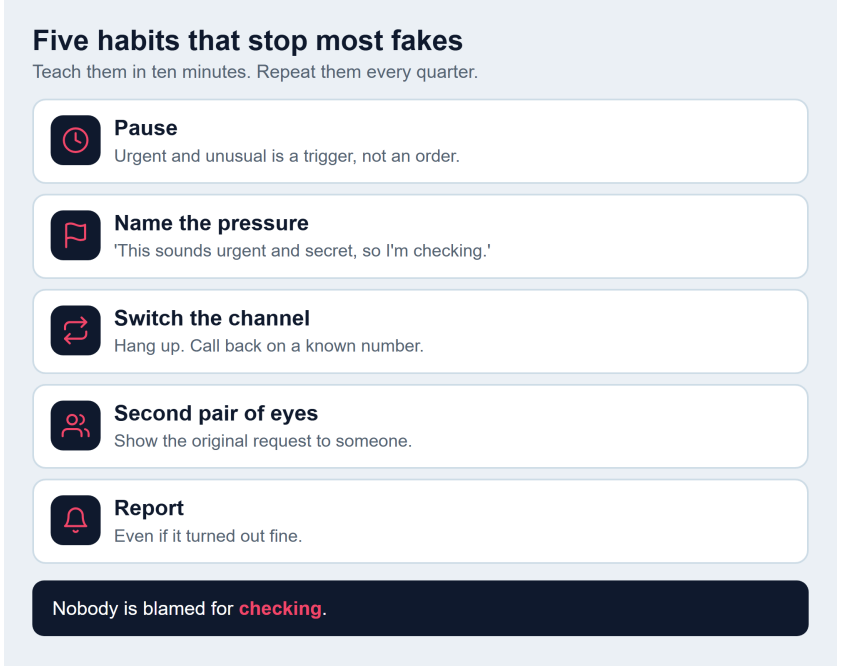
- **Authority.** "I'm the managing director."
- **Urgency.** "It has to go today."
- **Fear.** "We will lose the contract."
- **Helpfulness.** "Can you do me a favour?"
- **Secrecy.** "Don't mention this to anyone."

Each pressure targets a quality you want in your staff: respect, speed, loyalty, kindness, discretion. Training should not make people suspicious of everyone. It should make them **comfortable pausing**.



Photo: Staff on the front line need a script they can use at once

Five habits to teach



Five habits that stop most fakes

1. **Pause.** A request that is urgent and unusual is a trigger, not an order.
2. **Name the pressure.** "This sounds urgent and confidential, so I'm going to check."
3. **Switch the channel.** Hang up, call back on a known number.
4. **Get a second pair of eyes.** Show the original request to someone else.
5. **Report, even if it turns out fine.** A near miss shared protects the next person.

A script for staff

Give people the words, because the moment of pressure is a bad time to invent them.

On a call. "Thanks. For security, I verify all payment and account changes. I'll call you back on the number we hold and sort it straight away."

By email. "Thanks for letting us know. Before we update bank details we confirm by phone. We'll call the number on our file. We'll then action it within one working day."

When pushed. "I understand it's urgent. I can't make an exception to the process, and nor can anyone else. If this is genuine, a call-back will take five minutes."

No-blame reporting

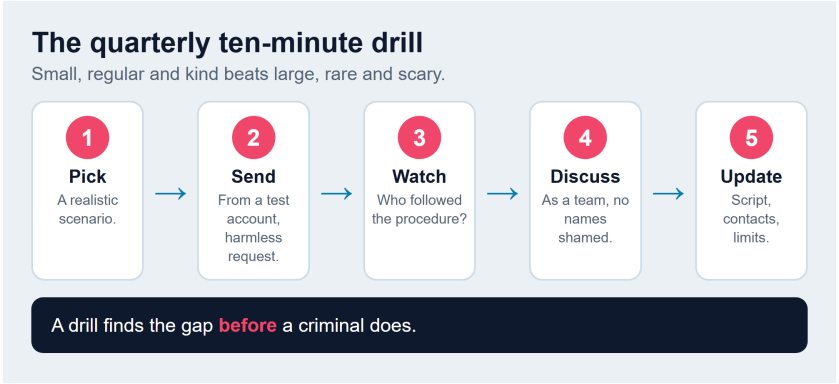
Staff who fear punishment hide mistakes and the fraud grows. Say it plainly: **nobody will be disciplined for reporting a suspicious request, or for falling for a good fake and reporting it immediately.** Deliberately skipping the process is different, and the policy should say so.

Fictional. At Hartwell Interiors, a junior bookkeeper paid a fake invoice and told the owner within the hour. Because the bank was called at once, £6,100 of £7,400 was recovered. The owner's first words were "thank you for telling me straight away". The following month, another team member reported a suspicious email within minutes.

Run small drills

Training once a year is not enough. Run a **ten-minute drill** each quarter:

1. Choose a realistic scenario (a boss message, a supplier change).
2. Send it from a test account to a few staff, with a harmless request.
3. Note who followed the procedure and who did not.
4. Discuss it as a team, with no names shamed.
5. Update the script, the contacts list or the limits.



The quarterly ten-minute drill

Protect your people from over-sharing

Your staff's public profiles are raw material. Review what is easy to find: org charts with names and job titles, "meet the team" pages with direct emails, out-of-office messages that say who is away and when, long videos of the owner speaking. You do not need to hide. You should know what an attacker can learn in an hour, and **keep operational detail** (who approves payments, who is travelling) out of public view.

Checklist: people

- ☐ Every person who handles money, accounts or access has had the five-habits briefing.
- ☐ Staff have the script and a printed call-back card.
- ☐ The owner has stated, in writing, that nobody is blamed for verifying.
- ☐ We run a ten-minute drill each quarter.
- ☐ Out-of-office messages do not announce who is away and who is in charge.

CHAPTER 10

Tools That Help (and Their Limits)



Technology can make fraud harder and verification quicker. It will not replace procedures. Treat tools as layers, not as a single wall.



Layers of defence for a small business

Layer 1: protect your email and domain

Many payment frauds begin with a spoofed or hijacked email. Three standards, set up through your email or domain provider, make it harder to forge messages that appear to come from your domain:

- **SPF** says which servers may send mail for your domain.
- **DKIM** adds a signature that proves the message was not altered.

- **DMARC** tells receiving servers what to do with messages that fail, and reports abuse.

Ask your provider to confirm all three are active and that DMARC is set to a policy that blocks failures once you have checked that it will not stop your own mail.[10] Also register obvious look-alike domains where practical, and turn on **multi-factor authentication** on every email account. Prefer app or hardware-key codes to text messages.

Layer 2: bank and payment controls

Talk to your bank about:

- **Payee-name checking.** In the euro area, banks must offer a Verification of Payee service from 9 October 2025, which compares the payee name and account number before a transfer. In the UK, Confirmation of Payee does something similar.[5][6] A "no match" result means stop and check. A "match" is not proof the account belongs to the right person for the right purpose.
- **Dual authorisation.** Require two approvals for payments above a limit.
- **Payment limits and new-payee delays.** Lower daily limits and a cooling-off period for new payees.
- **Alerts.** Text or app alerts for every payment, to more than one person.
- **A fraud contact.** The direct number for the bank's fraud team, saved in your contacts and printed on the call-back card.

Layer 3: identity and access

- **Multi-factor authentication** on banking, accounting, email, payroll and admin accounts.
- **Separate accounts for admin work**, so a stolen everyday login cannot change payees.
- **Role-based access.** Not everyone needs payment rights. Fewer people means fewer targets.
- **Password manager** and unique passwords.

- **Account recovery that does not rely on the same email** an attacker may already control.

Layer 4: customer and identity checks

For higher-risk onboarding, you can buy identity-verification services that read a document's chip or security features and run a live check. Choose carefully. Ask the provider how it tests against presentation attacks (the technical standard is ISO/IEC 30107-3),[11] where data is stored, how long, and which data-protection role it plays. Remember the GDPR obligations in Chapter 11.

Layer 5: detection tools

Some products claim to detect deepfake audio, video or documents. They can add a signal, but they make mistakes in both directions, and the best fakes are designed to beat them. Use them as one input, **never as the decision**. If the tool says "real" and the request is still a payment change, you still call back.



Photo: Tools are layers; the procedure is the foundation

What to avoid

- **Buying a tool instead of writing a procedure.**
- **Trusting a "verified" badge** on a message or profile.
- **Sending bank details through an unsecured channel** such as plain email or a chat group.

- **Keeping one shared login** for banking.

Checklist: tools

- ☐ SPF, DKIM and DMARC are active on our email domain.
- ☐ MFA is on email, banking, accounting and payroll.
- ☐ Dual authorisation and new-payee delays are switched on at the bank.
- ☐ We know how to use payee-name checking, and what a "no match" means.
- ☐ Alerts go to at least two people.

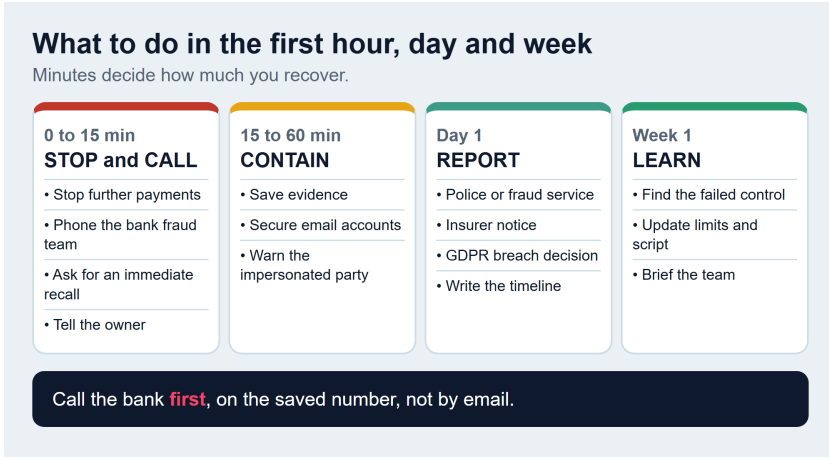
CHAPTER 11

When It Happens, and What the Law Says



Even with good procedures, a fake may get through. The first hour decides how much you recover. Prepare before you need it.

The first hour



What to do in the first hour, first day and first week

Minutes 0 to 15: stop and call

1. Stop any further payments to that account and freeze the related request.
2. **Phone your bank's fraud team immediately** on the number you saved, not by email. Say: "authorised payment obtained by fraud, please attempt a recall". Give the amount, time, sending account and receiving account details.
3. Tell the owner and the person who leads on finance.

Minutes 15 to 60: contain

4. Preserve evidence: do not delete messages, call logs or recordings. Take screenshots with timestamps and save the original email with its headers.
5. If an email account may have been taken over, change passwords and revoke active sessions from a different device, and turn on MFA.
6. Warn the supplier or customer being impersonated, by a verified channel, so they can warn others.

Day 1: report and review

7. Report to the police or national fraud service: in the UK, Action Fraud (now moving to a new reporting service); elsewhere, your national police or fraud portal.
8. Notify your insurer if you have cyber or crime cover. Many policies set strict notice periods.
9. Check whether **personal data** was exposed. If it was, the GDPR breach clock may have started (see below).
0. Write a short timeline while memories are fresh.

Week 1: learn

1. Find which control failed or was missing. Fix the process, not the person.
2. Update the contacts list, the limits and the script. Brief the team.

Will the money come back?

Sometimes. A bank recall works best when it is fast and the receiving account still holds funds; criminals move money on quickly, which is why minutes matter. Recovery is not guaranteed. Do not pay anyone who contacts you offering to "recover" your lost money for a fee; this is itself a common follow-up scam.

Who bears the loss?

The answer depends on country, payment type, the bank's terms and what happened. Three broad points, none of them legal advice:

- **Unauthorised vs authorised.** Under EU payment-services law (PSD2), a payer is generally protected for payments they did not authorise, with limits where they acted with gross negligence.[9] If an employee **authorises** a payment because they were deceived, the payment is generally treated as authorised, and recovery is harder.
- **UK reimbursement.** The UK has a mandatory reimbursement regime for authorised push payment fraud on Faster Payments and CHAPS, in force since October 2024, with a per-claim limit of £85,000. It is designed to protect consumers, microenterprises and charities, with conditions, and it is not the same as full cover for every business.[6]
- **Insurance.** Cyber and crime policies may cover social-engineering losses, but often with sub-limits, exclusions and a requirement that you followed a verification procedure. Read yours and ask your broker. Having a documented call-back procedure can help both the claim and the premium.

Personal data and the GDPR

Fakes often involve personal data on both sides.

- **If personal data was exposed**, for example a fake caller got into a customer account or an attacker accessed staff records, you may have a personal data breach. A controller must notify the supervisory authority without undue delay, and where feasible within **72 hours** of becoming aware, unless the breach is unlikely to result in a risk to people. The clock runs from awareness.[8]
- **If you collect identity data to verify people**, apply data minimisation: collect only what you need, say why, keep it only as long as necessary, and secure it. Copies of passports and IDs are high-risk to hold. Biometric data used to identify a person is special-category data under Article 9 and needs a lawful basis and extra care.[8] Prefer checks where you see a document and record that you did, instead of keeping a copy.
- **Staff and customers have rights.** If someone says their identity was used to deal with you, treat it as a data-subject matter and respond promptly.

Deepfakes and the EU AI Act

The AI Act's transparency rules (Article 50) require that people be told when they interact with an AI system, require providers of generative systems to mark synthetic output in a machine-readable way, and require deployers who publish deepfakes to disclose that content has been artificially generated or manipulated. The deepfake-disclosure duty was reported to apply from 2 August 2026, with a later date (2 December 2026) for marking by systems already on the market; sources differ on details, so check the final text.[7] Two practical points for a small business. First, these rules apply to **honest** users of AI: criminals will not follow them, so labels cannot be your defence. Second, if **you** use AI voices, avatars or synthetic images in marketing or customer service, you may owe disclosure.

Other legal points to keep in mind

- **Fraud is a crime** under national law, and facilitating it knowingly can be too. Report promptly and keep records.
- **UK failure-to-prevent-fraud offence.** From 1 September 2025 certain **large** organisations can be liable if an associated person commits fraud for their benefit and they lack reasonable prevention procedures. Small businesses are exempt, but larger customers may ask suppliers to show fraud controls.[12]
- **Contracts.** Check whether your terms with suppliers say whose risk it is if payments go to a wrong account after a verified change.

Checklist: if it happens

- ☐ The bank's fraud number is saved and printed on the call-back card.
- ☐ We have a one-page incident sheet (Appendix E) and know who runs the response.
- ☐ We know our insurer's notice period and what the policy covers.
- ☐ We know who decides whether a breach notification is needed, and by when.
- ☐ We keep evidence and write a timeline on the day.

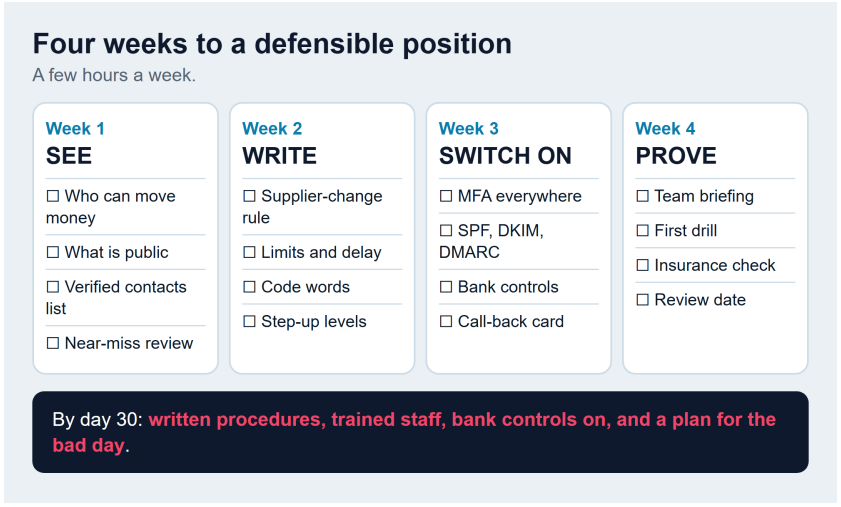
CHAPTER 12

Your 30-Day Plan and Five Case Files



You do not need to do everything at once. A few hours a week for a month gives you a defensible position: procedures in writing, trained staff, switched-on bank controls and a plan for the bad day.

The 30-day plan



Four weeks to a defensible position

Week 1: See

- ☐ List everyone who can move money, change bank details or grant access, and how they can be reached.
- ☐ List where your voice, face and role are public.
- ☐ Build a verified contacts list for suppliers, key customers and senior staff, using numbers from your own records.
- ☐ Review the last twelve months for near misses.

Week 2: Write

- ☐ Write the supplier-change procedure (Chapter 8) and the one-page rule (Chapter 6).
- ☐ Set approval limits and a cooling-off delay.
- ☐ Agree code words for the owner, finance lead and key suppliers.
- ☐ Write the customer step-up levels (Chapter 7).

Week 3: Switch on

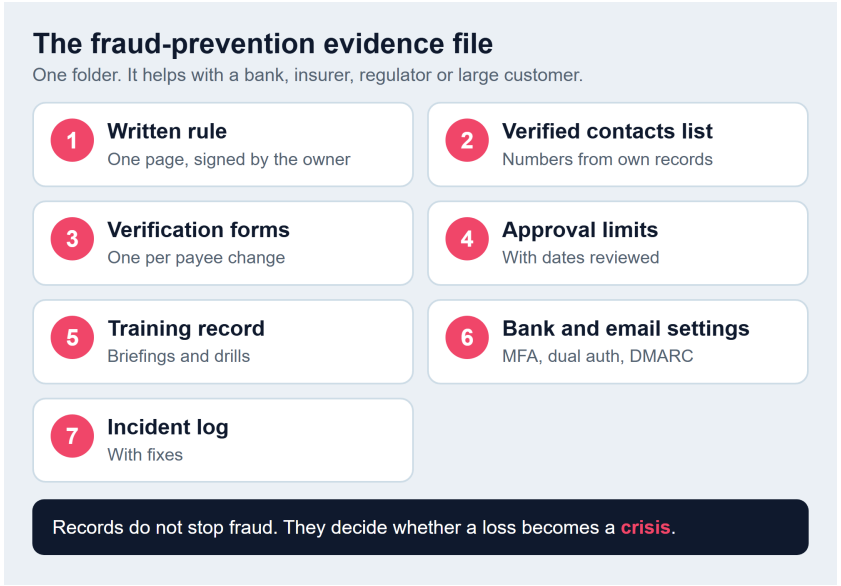
- ☐ Turn on MFA on email, banking, accounting and payroll.
- ☐ Ask your provider to confirm SPF, DKIM and DMARC.
- ☐ Ask your bank for dual authorisation, new-payee delays, alerts and payee-name checking.
- ☐ Save the bank fraud number; print the call-back card (Appendix B).

Week 4: Prove

- ☐ Brief the team on the five habits and hand out the script.
- ☐ Run a ten-minute drill.
- ☐ Check your insurance cover and its conditions.
- ☐ Set a quarterly review date (Appendix F).

The evidence file

Keep one folder that shows what you did. It helps a bank, an insurer, a regulator or a larger customer asking about your controls.



The fraud-prevention evidence file

Five fictional case files

Read each, decide what you would do, then compare with the notes. Every business and person is invented.

Case 1: The urgent director

Setting. Alderney Print (nine staff). At 4.40pm on a Friday, the bookkeeper receives an email from the "owner", sent from a personal address, asking for £14,500 to a new supplier "before the weekend". A follow-up voice message arrives, in the owner's voice, saying she is travelling.

Questions. Which signals matter? What do you do first?

Notes. New payee, urgency, secrecy, personal address, voice message (a claim, not proof). Call back on the owner's mobile from the contacts list. Apply the new-payee rule: two approvers and a delay. Nothing is paid before the real owner confirms.

Case 2: The new bank details

Setting. Tidewell Foods. The supplier emails a letter on headed paper saying the account has changed, with a polite request to update "before the next run".

Questions. Is the letter good evidence? Who should check, and how?

Notes. The letter is a claim. Quarantine the request, call the supplier on the number from your records, speak to someone you know, read back the new details, get second approval, apply the cooling-off delay. Record all of it.

Case 3: The perfect candidate

Setting. Foxglove Digital hires a remote developer after two video interviews. On day two the person asks for admin access and wants equipment sent to a parcel locker.

Questions. What would you have done at hiring? What now?

Notes. Live verification on your own link with ID shown to camera; staged access; equipment to a verified address; payment to an account in the person's name. Pause access and verify now.

Case 4: The locked-out customer

Setting. Wren & Co. sells subscriptions. A caller who sounds like a long-standing customer asks to change the account email and the payout bank details, saying the old phone was lost.

Questions. What does the script say?

Notes. Do not change details on the call. Send confirmation to the old contact details, apply the delay, step up identity checks, and require confirmation from the old email before a change takes effect.

Case 5: The video meeting

Setting. Kestrel Marine. A finance officer is invited to an unscheduled video call with the "directors" to approve a confidential acquisition payment of £120,000.

Questions. What is the call proving? What is the control?

Notes. The call is a claim. The payment follows the normal process: new payee, call-back to each director on a known number, two approvers, a delay and a bank payee check. A genuine confidential deal can survive a delay of one working day; a fraud cannot.

> **The rule.** A real request survives a check. A fake does not. If a check would be a problem, that is the answer.

APPENDIX A

Payment-Change Verification Form

Complete one form for every change of bank details or new payee. Keep with the evidence file.

Item	Details
Date and time request received	
How received (email, phone, post, message)	
Supplier or payee name	
Requested by (name and role claimed)	
New account name and last four digits	
Reason given for the change	
Number called to verify (from own records, source)	
Person spoken to	
Details read back and confirmed (yes / no)	
Verified by (name, date, time)	
Second approver (name, date, time)	
Cooling-off ends	
Test payment or name check done	
Notes	

APPENDIX B

Call-Back Card

Print on a card and keep it by the finance desk and the phone.

Before you act on any request to pay, change or reset:

1. **Stop.** Is there a change, urgency, secrecy or authority? If yes, verify.
2. **Hang up or do not reply.** Do not use the number or address in the message.
3. **Call back** on a number from our contacts list: _____
4. **Ask** the agreed code word or a question only they can answer.
5. **Second person** approves anything above our limit of _____.
6. **Record** what you checked.

Bank fraud team (saved number): _____

If it goes wrong: ring the bank first, then tell _____.

APPENDIX C

Customer Step-Up Checklist

Level	Checks to complete	Done (date, initials)
1. Basic	Card security checks passed; confirmation sent to email given	
2. Match	Payer name matches customer; delivery address confirmed; confirmation to address on file	
3. Verify	Live call to a number looked up independently; registry check for businesses; payment from an account in the customer's name	
4. Hold	Shipment paused; reason recorded; refund to original method only; manager informed	

Triggers that move a customer up a level (tick those you adopt):

- ☐ Order above our value limit of _____
- ☐ Credit terms requested
- ☐ Name on payment differs from customer name
- ☐ Delivery to forwarder, locker or hotel
- ☐ Change of email, phone, address or bank details
- ☐ Pressure to skip normal checks

APPENDIX D

Staff Scripts

Caller asks for a payment or account change. "Thank you. For security we verify all payment and account changes by calling back on the number we hold. I'll ring you in a few minutes."

Caller says it is the owner. "Thanks. We have a rule that anything involving money is double-checked, no matter who asks. I'll ring you on your mobile now."

Caller pushes back. "I understand it's urgent. I can't make an exception, and nobody here can. If it's genuine, this will take five minutes."

Customer wants to change contact details. "To protect your account, we'll send a confirmation to the details we currently hold. Once you approve it, the change takes effect after 24 hours."

Candidate or contractor asks for early access. "Access is added in stages. We'll review it after your first week."

Someone asks you to keep it secret. "I'm not able to keep a payment request from the finance lead. Let me bring them in."

APPENDIX E

Incident Log

Item	Details
Date and time discovered	
Discovered by	
What happened (short)	
Amount, accounts, systems or data involved	
Bank fraud team called (time, reference)	
Police or fraud service report (reference)	
Insurer notified (time, reference)	
Personal data involved? Breach decision and time	
Evidence saved (where)	
Control that failed or was missing	
Fix and owner	
Date team briefed	

APPENDIX F

Quarterly Review Sheet

Question	Yes / No	Action and date
Is the contacts list verified and current?		
Have approval limits been reviewed?		
Have code words been changed?		
Did anyone leave or join with payment or access rights?		
Were there near misses or alerts this quarter?		
Did we run a drill? Result?		
Are MFA, SPF, DKIM and DMARC still active?		
Has the insurance cover or condition changed?		
Have we reviewed what is public about our team?		

Glossary

Authorised push payment (APP) fraud. Fraud in which the victim is deceived into authorising a payment to the criminal.

Business email compromise (BEC). Fraud using a spoofed or taken-over business email account to obtain payments or information.

Call-back. Verifying a request by calling a number you already hold, rather than one supplied in the request.

Cooling-off delay. A waiting period before a change of payee or access takes effect.

Deepfake. Synthetic audio, image or video that imitates a real person or event.

DMARC, DKIM, SPF. Email standards that help receiving servers detect messages forged to look as if they come from your domain.

Liveness check. A test that tries to confirm a real, present person is in front of the camera.

Multi-factor authentication (MFA). Signing in with more than a password, such as an app code or hardware key.

Out-of-band verification. Checking a request through a channel different from the one it arrived on.

Social engineering. Manipulating people into acting or sharing information, rather than breaking technology.

Synthetic identity. An identity assembled from real and invented details.

Voice cloning. Using AI to generate speech that imitates a particular person's voice.

A Note on GDPRGard.eu

Verifying people means handling personal data, and fraud incidents can become data breaches. If this book has raised questions about records of processing, breach reporting, data-subject requests or how long to keep identity documents, **GDPRGard.eu** offers free tools, guides and articles written in plain English for small organisations.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that business owners should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other readers find it.

Notes and Sources

Research cut-off: 30 October 2026. Items marked (read) were consulted for this edition through search results and secondary reporting; the others rest on the author's working knowledge of well-known public records and should be re-checked against the primary source before you rely on them.

1. FBI Internet Crime Complaint Center, Internet Crime Report 2024 (April 2025): business email compromise, 21,442 complaints and close to $2.8 billion in reported losses; total reported losses of $16.6 billion across all crime types (read, through secondary reporting). ic3.gov. US data; later reports may have updated these figures.
2. Reporting on the Arup deepfake video-call fraud, Hong Kong, January 2024: about HK$200 million (US$25.6 million) sent in 15 transactions to five accounts; Arup confirmed it was the victim in May 2024 (read, through CNN, Fortune and other news reports citing Hong Kong police).
3. Reporting on the attempted deepfake fraud against WPP's chief executive, May 2024, including WPP's statement to The Guardian (read, through press reports).
4. Reporting on the attempted voice-clone fraud against Ferrari, July 2024, including the executive's use of a security question (read, through Bloomberg and Fortune reports).
5. Regulation (EU) 2024/886 amending the SEPA and cross-border payments regulations (Instant Payments Regulation): Verification of Payee required from 9 October 2025 in the euro area and 9 July 2027 for other Member States (read, through ECB and law-firm summaries). Check your bank's service and any later changes.
6. UK Confirmation of Payee (Pay.UK); Payment Systems Regulator rules on mandatory reimbursement of authorised push payment fraud, in force 7 October 2024, with a £85,000 per-claim limit, covering consumers, microenterprises and charities (from working knowledge; check the current rules).
7. Regulation (EU) 2024/1689 (AI Act), Article 50, and the Digital Omnibus amendments: deepfake disclosure reported to apply from 2 August 2026 and a transitional date of 2 December 2026 for marking by systems already on the

market (read, through law-firm and trade commentary; sources differ, the Official Journal text should be checked).

8. GDPR (Regulation (EU) 2016/679), Articles 5(1)(c) (data minimisation), 9 (special categories, including biometric data used for identification), 33 and 34 (breach notification). eur-lex.europa.eu. EDPB Guidelines 9/2022 on personal data breach notification.
9. Directive (EU) 2015/2366 (PSD2), Articles 73 and 74 on liability for unauthorised payments, including the gross-negligence limit. National implementation differs.
10. UK National Cyber Security Centre guidance on email security and anti-spoofing (SPF, DKIM, DMARC); similar guidance exists from other national agencies.
11. ISO/IEC 30107-3, Information technology: Biometric presentation attack detection, testing and reporting.
12. Economic Crime and Corporate Transparency Act 2023 (UK), failure to prevent fraud offence, in force 1 September 2025, applying to large organisations (from working knowledge; check the current guidance).